

Enforce and monitor compliance with software installation policies using [Assignment: organization-defined automated mechanisms]. Discussion: Organizations enforce and monitor compliance with software installation policies using automated mechanisms to more quickly detect and respond to unauthorized software installation which can be an indicator of an internal or external hostile attack. Related Controls: None. References: None.

NIST SP 800-53 Rev 5 control CM-12.1 (Automated Tools to Support Information Location) is assessed by examining, interviewing, and testing: CM-12.1 · Automated Tools to Support Information Location Control Statement: Use automated tools to identify [organization-defined parameter] on [organization-defined parameter] to ensure controls are in place to protect organizational information and individual privacy. Supplemental Guidance: Use automated tools to identify [organization-defined parameter] on [organization-defined parameter] to ensure controls are in place to protect organizational information and individual privacy. The use

NIST SP 800-171 Rev 3 control 03.04.04 (03.04.04 Impact Analyses) requires organizations to implement the following: Control Statement: SR-03.04.04.a Analyze changes to the system to determine potential security impacts prior to change implementation. SR-03.04.04.b Verify that the security requirements for the system continue to be satisfied after the system changes have been implemented. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.04.

Under the FedRAMP Moderate baseline, CM-7.5 (CM-7.5 Authorized Software · Allow-by-exception): FedRAMP Moderate Baseline · CM-7.5 · Authorized Software · Allow-by-exception Control Statement: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs on the system; and (c) Review and update the list of authorized software programs [organization-defined parameter]. Supplemental Guidance: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the

NIST SP 800-53 Rev 5 control CM-7.4 (Unauthorized Software · Deny-by-exception) summarizes the requirements for this control: CM-7.4 · Unauthorized Software · Deny-by-exception Control Statement: (a) Identify [organization-defined parameter]; (b) Employ an allow-all, deny-by-exception policy to prohibit the execution of unauthorized software programs on the system; and (c) Review and update the list of unauthorized software programs [organization-defined parameter]. Supplemental Guidance: (a) Identify [organization-defined parameter]; (b) Employ an allow-all, deny-by-exception policy to prohibit the execution of unau

NIST SP 800-171 Rev 3 control 03.04.01 (03.04.01 Baseline Configuration) is assessed by examining the following: Assessment Objectives: - a current baseline configuration of the system is developed. - a current baseline configuration of the system is maintained under configuration control. - the baseline configuration of the system is updated [organization-defined parameter]. - the baseline configuration of the system is reviewed when system components are installed or modified. - the baseline configuration of the system is updated when system components are installed or modified. - the baseline configuration of the system is reviewed [organization-defined parameter].

From the NIST SP 800-172 Rev 3 Final Public Draft: ADVERSARY EFFECTS 1023 Preclude (Preempt), Impede (Exert), Limit (Shorten, Reduce) REFERENCES Source Control: CM-02(03) 03.0 4.07E Testing, Validation, and Documentation of Changes Test, validate, and document changes to the system before finalizing the implementation of the changes. DISCUSSION Changes to systems include modifications to hardware, software, or firmware components and defined configuration settings. Organizations ensure that testing does not interfere with system operations that support organizational missions and business functions. Individuals or groups that conduct the tests understand the system security policies and procedures associated with the specific facilities or processes. Operational systems may need to be taken offline or replicated to the exte

Under the FedRAMP Moderate baseline, CM-4.2 (CM-4.2 Verification of Controls): FedRAMP Moderate Baseline · CM-4.2 · Verification of Controls Control Statement: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired outcome with regard to meeting the security and privacy requirements for the system. Supplemental Guidance: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired outcome with regard to meeting the security a

NIST SP 800-171 Rev 3 control 03.04.08 (03.04.08 Authorized Software · Allow by Exception) is assessed by examining the following: Assessment Objectives: - software programs authorized to execute on the system are identified. - a deny-all, allow-by-exception policy for the execution of authorized software programs on the system is implemented. - the list of authorized software programs is reviewed and updated [organization-defined parameter].

NIST SP 800-53 Rev 5 control CM-11.3 (Automated Enforcement and Monitoring) summarizes the requirements for this control: CM-11.3 · Automated Enforcement and Monitoring Control Statement: Enforce and monitor compliance with software installation policies using [organization-defined parameter]. Supplemental Guidance: Enforce and monitor compliance with software installation policies using [organization-defined parameter]. Organizations enforce and monitor compliance with software installation policies using automated mechanisms to more quickly detect and respond to unauthorized software installation which can be a

NIST SP 800-53 Rev 5 control CM-5.6 (Limit Library Privileges) summarizes the requirements for this control: CM-5.6 · Limit Library Privileges Control Statement: Limit privileges to change software resident within software libraries. Supplemental Guidance: Limit privileges to change software resident within software libraries. Software libraries include privileged programs.

NIST SP 800-53 Rev 5 control CM-13 (Data Action Mapping) summarizes the requirements for this control: CM-13 · Data Action Mapping Control Statement: Develop and document a map of system data actions. Supplemental Guidance: Develop and document a map of system data actions. Data actions are system operations that process personally identifiable information. The processing of such information encompasses the full information life cycle, which includes collection, generation, transformation, use, disclosure, retention, and disposal. A map of system data actions includes discrete data actions, ele

NIST SP 800-53 Rev 5 control CM-3.3 (Automated Change Implementation) is assessed by examining, interviewing, and testing: CM-3.3 · Automated Change Implementation Control Statement: Implement changes to the current system baseline and deploy the updated baseline across the installed base using [organization-defined parameter]. Supplemental Guidance: Implement changes to the current system baseline and deploy the updated baseline across the installed base using [organization-defined parameter]. Automated tools can improve the accuracy, consistency, and availability of configuration baseline information. Automation

and determining how potential changes to a system create new risks to the privacy of individuals and the ability of implemented controls to mitigate those risks. Impact analyses also include risk assessments to understand the impact of the changes and determine if additional controls are required. Related Controls: CA-7, CM-3, CM-8, CM-9, MA-2, RA-3, RA-5, RA-8, SA-5, SA-8, SA-10, SI-2. Control Enhancements: (1) IMPACT ANALYSES | SEPARATE TEST ENVIRONMENTS Analyze changes to the system in a separate test environment before implementation in an operational environment, looking for security and privacy impacts due to flaws, weaknesses, incompatibility, or intentional malice. Discussion: A separate test environment requires an environment that is physically or logically separate and distinct from the operational environment.

CM-9 · Configuration Management Plan Control Statement: Develop, document, and implement a configuration management plan for the system that: a. Addresses roles, responsibilities, and configuration management processes and procedures; b. Establishes a process for identifying configuration items throughout the system development life cycle and for managing the configuration of the configuration items; c. Defines the configuration items for the system and places the configuration items under configuration management; d. Is reviewed and approved by [organization-defined parameter] ; and e. Protects the configuration management plan from unauthorized disclosure

and modification. Supplemental Guidance: Develop, document, and implement a configuration management plan for the system that: a. Addresses roles, responsibilities, and configuration management processes and procedures; b. Establishes a process for identifying configuration items throughout the system development life cycle and for managing the configuration of the configuration items; c. Defines the configuration items for the system and places the configuration items under configuration management; d. Is reviewed and approved by [organization-defined parameter] ; and e. Protects the configuration management plan from unauthorized disclosure and modification. Configuration management activities occur throughout the system development life cycle. As such, there are developmental configuration management activities (e.g., the control of code and software libraries) and operational configuration management activities (e.g., control of installed components and how the components are configured). Configuration management plans satisfy the requirements in configuration management policies while being tailored to individual systems. Configuration management plans define processes and procedures for how configuration management is used to support system development life cycle activities. Configuration management plans are generated during the development and acquisition stage of the system development life cycle. The plans describe how to advance changes through change management processes; update configuration settings and baselines; maintain component inventories; control development, test, and operational environments; and develop, release, and update key documents. Organizations can employ templates to help ensure the consistent and timely development and implementation of configuration management plans. Templates can represent a configuration management plan for the organization with subsets of the plan implemented on a system by system basis. Configuration management approval processes include the designation of key stakeholders responsible for reviewing and approving proposed changes to systems, and personnel who conduct security and privacy impact analyses prior to the implementation of changes to the systems. Configuration items are the system components, such as the hardware, software, firmware, and documentation to be configuration-managed. As systems continue through the system development life cycle, new configuration items may be identified, and some existing configuration items may no longer need to be under configuration control.

and settings for functions, protocols, ports, services, and remote connections. Privacy parameters are parameters impacting the privacy posture of systems, including the parameters required to satisfy other privacy controls. Privacy parameters include settings for access controls, data processing preferences, and processing and retention permissions. Organizations establish organization-wide configuration settings and subsequently derive specific configuration settings for systems. The established settings become part of the configuration baseline for the system.

CM-8.4 · Accountability Information Control Statement: Include in the system component inventory information, a means for identifying by [organization-defined parameter] , individuals responsible and accountable for administering those components. Supplemental Guidance: Include in the system component inventory information, a means for identifying by [organization-defined parameter] , individuals responsible and accountable for administering those components. Identifying individuals who are responsible and accountable for administering system components ensures that the assigned components are properly administered and that organizations can contact those individuals if some action is required (e.g., when the component is determined to be the source of a breach, needs to be recalled or replaced, or needs to be relocated).

NIST SP 800-53 Rev 5 control CM-8.7 (Centralized Repository) summarizes the requirements for this control: CM-8.7 · Centralized Repository Control Statement: Provide a centralized repository for the inventory of system components. Supplemental Guidance: Provide a centralized repository for the inventory of system components. Organizations may implement centralized system component inventories that include components from all organizational systems. Centralized repositories of component inventories provide opportunities for efficiencies in accounting for organizational hardware, software, and firmware

NIST SP 800-171 Rev 3 control 03.04.03 (03.04.03 Configuration Change Control) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Configuration Management (CM) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control CM-3.4 (Security and Privacy Representatives) summarizes the

requirements for this control: CM-3.4 · Security and Privacy Representatives Control Statement: Require [organization-defined parameter] to be members of the [organization-defined parameter]. Supplemental Guidance: Require [organization-defined parameter] to be members of the [organization-defined parameter]. Information security and privacy representatives include system security officers, senior agency information security officers, senior agency officials for privacy, or system privacy officers. Representation by personn

NIST SP 800-171 Rev 3 control 03.04.05 (03.04.05 Access Restrictions for Change) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Configuration Management (CM) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Control CM-9: gned within organizations, system developers may be tasked with developing configuration management processes using personnel who are not directly involved in system development or system integration. This separation of duties ensures that organizations establish and maintain a sufficient degree of independence between the system development and integration processes and configuration management processes to facilitate quality control and more effective oversight. Related Controls: None. References: [SP 800-128].

Under the FedRAMP Moderate baseline, CM-9 (CM-9 Configuration Management Plan): FedRAMP Moderate Baseline · CM-9 · Configuration Management Plan Control Statement: Develop, document, and implement a configuration management plan for the system that: a. Addresses roles, responsibilities, and configuration management processes and procedures; b. Establishes a process for identifying configuration items throughout the system development life cycle and for managing the configuration of the configuration items; c. Defines the configuration items for the system and places the co

CM-7.6 · Confined Environments with Limited Privileges Control Statement: Require that the following user-installed software execute in a confined physical or virtual machine environment with limited privileges: [organization-defined parameter]. Supplemental Guidance: Require that the following user-installed software execute in a confined physical or virtual machine environment with limited privileges: [organization-defined parameter]. Organizations identify software that may be of concern regarding its origin or potential for containing malicious code. For this type of software, user installations occur in confined environments of operation to limit or contain damage from malicious code that may be executed.

Under the FedRAMP Moderate baseline, CM-2 (CM-2 Baseline Configuration): FedRAMP Moderate Baseline · CM-2 · Baseline Configuration Control Statement: a. Develop, document, and maintain under configuration control, a current baseline configuration of the system; and b. Review and update the baseline configuration of the system: 1. [organization-defined parameter]; 2. When required due to [organization-defined parameter] ; and 3. When system components are installed or upgraded. Supplemental Guidance: a. Develop, document, and maintain under configuration cont

Under the FedRAMP Moderate baseline, CM-4 (CM-4 Impact Analyses): FedRAMP Moderate Baseline · CM-4 · Impact Analyses Control Statement: Analyze changes to the system to determine potential security and privacy impacts prior to change implementation. Supplemental Guidance: Analyze changes to the system to determine potential security and privacy impacts prior to change implementation. Organizational personnel with security or privacy responsibilities conduct impact analyses. Individuals conducting impact analyses possess the necessary skills and technical exp

NIST SP 800-53 Rev 5 control CM-3.4 (Security and Privacy Representatives) is defined as follows: CM-3.4 · Security and Privacy Representatives Control Statement: Require [organization-defined parameter] to be members of the [organization-defined parameter]. Supplemental Guidance: Require [organization-defined parameter] to be members of the [organization-defined parameter]. Information security and privacy representatives include system security officers, senior agency information security officers, senior agency officials for privacy, or system privacy officers. Representation by personnel with information security and privacy expertise is important because changes to system configurat

Under the FedRAMP Moderate baseline, CM-3.2 (CM-3.2 Testing, Validation, and Documentation of

Changes): FedRAMP Moderate Baseline · CM-3.2 · Testing, Validation, and Documentation of Changes
Control Statement: Test, validate, and document changes to the system before finalizing the implementation of the changes. Supplemental Guidance: Test, validate, and document changes to the system before finalizing the implementation of the changes. Changes to systems include modifications to hardware, software, or firmware components and configuration settings defined in [CM-6](#cm-6) . Organizations ensure

NIST SP 800-171 Rev 3 control 03.04.10 (03.04.10 System Component Inventory) requires organizations to implement the following: Control Statement: SR-03.04.10.a Develop and document an inventory of system components. SR-03.04.10.b Review and update the system component inventory [organization-defined parameter]. SR-03.04.10.c Update the system component inventory as part of installations, removals, and system updates. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.10.

NIST SP 800-171 Rev 3 control 03.04.10 (03.04.10 System Component Inventory) is assessed by examining the following: Assessment Objectives: - an inventory of system components is developed and documented. - the system component inventory is reviewed [organization-defined parameter]. - the system component inventory is updated [organization-defined parameter]. - the system component inventory is updated as part of component installations. - the system component inventory is updated as part of component removals. - the system component inventory is updated as part of system updates.

NIST SP 800-53 Rev 5 control CM-4 (Impact Analyses) is assessed by examining, interviewing, and testing: CM-4 · Impact Analyses Control Statement: Analyze changes to the system to determine potential security and privacy impacts prior to change implementation. Supplemental Guidance: Analyze changes to the system to determine potential security and privacy impacts prior to change implementation. Organizational personnel with security or privacy responsibilities conduct impact analyses. Individuals conducting impact analyses possess the necessary skills and technical expertise to analyze the change

NIST SP 800-53 Rev 5 control CM-9.1 (Assignment of Responsibility) summarizes the requirements for this control: CM-9.1 · Assignment of Responsibility Control Statement: Assign responsibility for developing the configuration management process to organizational personnel that are not directly involved in system development. Supplemental Guidance: Assign responsibility for developing the configuration management process to organizational personnel that are not directly involved in system development. In the absence of dedicated configuration management teams assigned within organizations, system developer

NIST SP 800-171 Rev 3 control 03.04.11 (03.04.11 Information Location) is assessed by examining the following: Assessment Objectives: - the location of CUI is identified and documented. - the system components on which CUI is processed are identified and documented. - the system components on which CUI is stored are identified and documented. - changes to the system or system component location where CUI is processed are documented. - changes to the system or system component location where CUI is stored are documented.

NIST SP 800-171 Rev 3 control 03.04.10 (03.04.10 System Component Inventory) falls under the Configuration Management family. Control Statement: SR-03.04.10.a Develop and document an inventory of system components. SR-03.04.10.b Review and update the system component inventory [organization-defined parameter]. SR-03.04.10.c Update the system component inventory as part of installations, removals, and system updates. Supplemental Guidance: System components are discrete, identifiable assets (i.e., hardware, software, and firmware elements) that compose a system. Organizations may implement centralized system component inventories that include components from all systems. In such situations, organizations ensure that the inventories include the system-specific information required for component accountability. The information necessary for effective accountability of system components includes the system name

Under the FedRAMP Low baseline, CM-11 (CM-11 User-installed Software): FedRAMP Low Baseline · CM-11 · User-installed Software Control Statement: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation policies through

the following methods: [organization-defined parameter] ; and c. Monitor policy compliance [organization-defined parameter]. Supplemental Guidance: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation pol

From the NIST SP 800-172 Rev 3 Final Public Draft: and maintain authoritative (i.e., up-to-date, complete, accurate, and available) 961 baseline configurations for systems that include hardware and software inventory tools, configuration management tools, and network management tools. Tools can be used to track version numbers on operating systems, applications, types of software installed, and current patch levels. This requirement enhances SP 800-171 requirement 03.04.10. P
ROTECTION STRATEGY PRA, DLO ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Expose (Detect)
REFERENCES Source Control: CM-08(02) 03.0 4.04E Automation Support for Baseline Configuration
Maintain the currency, completeness, accuracy, and availability of the baseline configuration of the system using [Assignment: organization-defined automated mech

Under the FedRAMP Low baseline, CM-5 (CM-5 Access Restrictions for Change): FedRAMP Low Baseline · CM-5 · Access Restrictions for Change Control Statement: Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system. Supplemental Guidance: Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system. Changes to the hardware, software, or firmware components of systems or the operational procedures related to the system can potentially have significant eff

Under the FedRAMP Moderate baseline, CM-12 (CM-12 Information Location): FedRAMP Moderate Baseline · CM-12 · Information Location Control Statement: a. Identify and document the location of [organization-defined parameter] and the specific system components on which the information is processed and stored; b. Identify and document the users who have access to the system and system components where the information is processed and stored; and c. Document changes to the location (i.e., system or system components) where the information is processed and stored. Supple

NIST SP 800-171 Rev 3 control 03.04.12 (03.04.12 System and Component Configuration for High-Risk Areas) requires organizations to implement the following: Control Statement: SR-03.04.12.a Issue systems or system components with the following configurations to individuals traveling to high-risk locations: [organization-defined parameter]. SR-03.04.12.b Apply the following security requirements to the systems or components when the individuals return from travel: [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.12.

NIST SP 800-171 Rev 3 control 03.04.04 (03.04.04 Impact Analyses) requires organizations to implement the following: Control Statement: SR-03.04.04.a Analyze changes to the system to determine potential security impacts prior to change implementation. SR-03.04.04.b Verify that the security requirements for the system continue to be satisfied after the system changes have been implemented. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.04.

NIST SP 800-53 Rev 5 control CM-3.5 (Automated Security Response) summarizes the requirements for this control: CM-3.5 · Automated Security Response Control Statement: Implement the following security responses automatically if baseline configurations are changed in an unauthorized manner: [organization-defined parameter]. Supplemental Guidance: Implement the following security responses automatically if baseline configurations are changed in an unauthorized manner: [organization-defined parameter]. Automated security responses include halting selected system functions, halting system processing, and is

Under the FedRAMP Low baseline, CM-7 (CM-7 Least Functionality): FedRAMP Low Baseline · CM-7 · Least Functionality Control Statement: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [organization-defined parameter]. Supplemental Guidance: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [org

Under the FedRAMP Moderate baseline, CM-6.1 (CM-6.1 Automated Management, Application, and Verification): FedRAMP Moderate Baseline · CM-6.1 · Automated Management, Application, and Verification Control Statement: Manage, apply, and verify configuration settings for [organization-defined parameter] using [organization-defined parameter]. Supplemental Guidance: Manage, apply, and verify configuration settings for [organization-defined parameter] using [organization-defined parameter]. Automated tools (e.g., hardening tools, baseline configuration tools) can improve the accuracy, consistency, and av

NIST SP 800-53 Rev 5 control CM-2.6 (Development and Test Environments) is assessed by examining, interviewing, and testing: CM-2.6 · Development and Test Environments Control Statement: Maintain a baseline configuration for system development and test environments that is managed separately from the operational baseline configuration. Supplemental Guidance: Maintain a baseline configuration for system development and test environments that is managed separately from the operational baseline configuration. Establishing separate baseline configurations for development, testing, and operational environments protects s

Under the FedRAMP Moderate baseline, CM-2.3 (CM-2.3 Retention of Previous Configurations): FedRAMP Moderate Baseline · CM-2.3 · Retention of Previous Configurations Control Statement: Retain [organization-defined parameter] of previous versions of baseline configurations of the system to support rollback. Supplemental Guidance: Retain [organization-defined parameter] of previous versions of baseline configurations of the system to support rollback. Retaining previous versions of baseline configurations to support rollback include hardware, software, firmware, configuration files, co

NIST SP 800-171 Rev 3 control 03.04.02 (03.04.02 Configuration Settings) requires organizations to implement the following: Control Statement: SR-03.04.02.a Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [organization-defined parameter] . SR-03.04.02.b Identify, document, and approve any deviations from established configuration settings. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.02.

NIST SP 800-53 Rev 5 control CM-5.5 (Privilege Limitation for Production and Operation) summarizes the requirements for this control: CM-5.5 · Privilege Limitation for Production and Operation Control Statement: (a) Limit privileges to change system components and system-related information within a production or operational environment; and (b) Review and reevaluate privileges [organization-defined parameter]. Supplemental Guidance: (a) Limit privileges to change system components and system-related information within a production or operational environment; and (b) Review and reevaluate privileges [organization-defined par

Under the FedRAMP High baseline, CM-3.1 (CM-3.1 Automated Documentation, Notification, and Prohibition of Changes): FedRAMP High Baseline · CM-3.1 · Automated Documentation, Notification, and Prohibition of Changes Control Statement: Use [organization-defined parameter] to: (a) Document proposed changes to the system; (b) Notify [organization-defined parameter] of proposed changes to the system and request change approval; (c) Highlight proposed changes to the system that have not been approved or disapproved within [organization-defined parameter]; (d) Prohibit changes to the system until designated approva

Under the FedRAMP Moderate baseline, CM-5.1 (CM-5.1 Automated Access Enforcement and Audit Records): FedRAMP Moderate Baseline · CM-5.1 · Automated Access Enforcement and Audit Records Control Statement: (a) Enforce access restrictions using [organization-defined parameter] ; and (b) Automatically generate audit records of the enforcement actions. Supplemental Guidance: (a) Enforce access restrictions using [organization-defined parameter] ; and (b) Automatically generate audit records of the enforcement actions. Organizations log system accesses associated with applying configuration changes

NIST SP 800-171 Rev 3 control 03.04.10 (03.04.10 System Component Inventory) requires organizations to implement the following: Control Statement: SR-03.04.10.a Develop and document an inventory of system components. SR-03.04.10.b Review and update the system component inventory [organization-defined parameter]. SR-03.04.10.c Update the system component inventory as part of installations,

removals, and system updates. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.10.

CM-2.7 · Configure Systems and Components for High-risk Areas Control Statement: (a) Issue [organization-defined parameter] with [organization-defined parameter] to individuals traveling to locations that the organization deems to be of significant risk; and (b) Apply the following controls to the systems or components when the individuals return from travel: [organization-defined parameter]. Supplemental Guidance: (a) Issue [organization-defined parameter] with [organization-defined parameter] to individuals traveling to locations that the organization deems to be of significant risk; and (b) Apply the following controls to the systems or components when the individuals return from travel: [organization-defined parameter]. When it is known that systems or system components will be in high-risk areas external to the organization, additional controls may be implemented to counter the increased threat in such areas. For example, organizations can take actions for notebook computers used by individuals departing on and returning from travel. Actions include determining the locations that are of concern, defining the required configurations for the components, ensuring that components are configured as intended before travel is initiated, and applying controls to the components after travel is completed. Specially configured notebook computers include computers with sanitized hard drives, limited applications, and more stringent configuration settings. Controls applied to mobile devices upon return from travel include examining the mobile device for signs of physical tampering and purging and reimaging disk drives. Protecting information that resides on mobile devices is addressed in the [MP](#mp) (Media Protection) family.

Implementing 03.04.02 (03.04.02 Configuration Settings) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.04.02 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.02 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-171 Rev 3 control 03.04.06 (03.04.06 Least Functionality) is assessed by examining the following: Assessment Objectives: - the use of the following functions is prohibited or restricted: [organization-defined parameter]. - the use of the following ports is prohibited or restricted: [organization-defined parameter]. - the use of the following protocols is prohibited or restricted: [organization-defined parameter]. - the use of the following connections is prohibited or restricted: [organization-defined parameter]. - the use of the following services is prohibited or restricted: [organization-defined parameter]. - the system is reviewed [organization-defined parameter] to identify unnecessary

NIST SP 800-53 Rev 5 control CM-4.2 (Verification of Controls) is assessed by examining, interviewing, and testing: CM-4.2 · Verification of Controls Control Statement: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired outcome with regard to meeting the security and privacy requirements for the system. Supplemental Guidance: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired outcome with regard to meeting the security and privacy requirements for

NIST SP 800-53 Rev 5 control CM-8 (System Component Inventory) summarizes the requirements for this control: CM-8 · System Component Inventory Control Statement: a. Develop and document an inventory of system components that: 1. Accurately reflects the system; 2. Includes all components within the system; 3. Does not include duplicate accounting of components or components assigned to any other system; 4. Is at the level of granularity deemed necessary for tracking and reporting; and 5. Includes the following information to achieve system component accountability: [organization-defined param

NIST SP 800-171 Rev 3 control 03.04.12 (03.04.12 System and Component Configuration for High-Risk Areas) is assessed by examining the following: Assessment Objectives: - systems or system components with the following configurations are issued to individuals traveling to high-risk locations: [organization-defined parameter]. - the following security requirements are applied to the system or system components when the individuals return from travel: [organization-defined parameter].

NIST SP 800-53 Rev 5 control CM-9 (Configuration Management Plan) summarizes the requirements for this control: CM-9 · Configuration Management Plan Control Statement: Develop, document, and implement a configuration management plan for the system that: a. Addresses roles, responsibilities, and configuration management processes and procedures; b. Establishes a process for identifying configuration items throughout the system development life cycle and for managing the configuration of the configuration items; c. Defines the configuration items for the system and places the configuration items under conf

NIST SP 800-53 Rev 5 control CM-3.3 (Automated Change Implementation) summarizes the requirements for this control: CM-3.3 · Automated Change Implementation Control Statement: Implement changes to the current system baseline and deploy the updated baseline across the installed base using [organization-defined parameter]. Supplemental Guidance: Implement changes to the current system baseline and deploy the updated baseline across the installed base using [organization-defined parameter]. Automated tools can improve the accuracy, consistency, and availability of configuration baseline information. Automation

NIST SP 800-171 Rev 3 control 03.04.12 (03.04.12 System and Component Configuration for High-Risk Areas) is assessed by examining the following: Assessment Objectives: - systems or system components with the following configurations are issued to individuals traveling to high-risk locations: [organization-defined parameter]. - the following security requirements are applied to the system or system components when the individuals return from travel: [organization-defined parameter].

Under the FedRAMP Moderate baseline, CM-5.5 (CM-5.5 Privilege Limitation for Production and Operation): FedRAMP Moderate Baseline · CM-5.5 · Privilege Limitation for Production and Operation Control Statement: (a) Limit privileges to change system components and system-related information within a production or operational environment; and (b) Review and reevaluate privileges [organization-defined parameter]. Supplemental Guidance: (a) Limit privileges to change system components and system-related information within a production or operational environment; and (b) Review and reevaluate privileg

NIST SP 800-53 Rev 5 control CM-4.1 (Separate Test Environments) is assessed by examining, interviewing, and testing: CM-4.1 · Separate Test Environments Control Statement: Analyze changes to the system in a separate test environment before implementation in an operational environment, looking for security and privacy impacts due to flaws, weaknesses, incompatibility, or intentional malice. Supplemental Guidance: Analyze changes to the system in a separate test environment before implementation in an operational environment, looking for security and privacy impacts due to flaws, weaknesses, incompatibility, o

NIST SP 800-53 Rev 5 control CM-7.7 (Code Execution in Protected Environments) is assessed by examining, interviewing, and testing: CM-7.7 · Code Execution in Protected Environments Control Statement: Allow execution of binary or machine-executable code only in confined physical or virtual machine environments and with the explicit approval of [organization-defined parameter] when such code is: (a) Obtained from sources with limited or no warranty; and/or (b) Without the provision of source code. Supplemental Guidance: Allow execution of binary or machine-executable code only in confined physical or virtual machine environ

NIST SP 800-53 Rev 5 control CM-10.1 (Open-source Software) is defined as follows: CM-10.1 · Open-source Software Control Statement: Establish the following restrictions on the use of open-source software: [organization-defined parameter]. Supplemental Guidance: Establish the following restrictions on the use of open-source software: [organization-defined parameter]. Open-source software refers to software that is available in source code form. Certain software rights normally

reserved for copyright holders are routinely provided under software license agreements that permit individuals to study, change, and improve the software. From a security perspective, the major adva

NIST SP 800-171 Rev 3 control 03.04.12 (03.04.12 System and Component Configuration for High-Risk Areas) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Configuration Management (CM) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control CM-2.3 (Retention of Previous Configurations) summarizes the requirements for this control: CM-2.3 · Retention of Previous Configurations Control Statement: Retain [organization-defined parameter] of previous versions of baseline configurations of the system to support rollback. Supplemental Guidance: Retain [organization-defined parameter] of previous versions of baseline configurations of the system to support rollback. Retaining previous versions of baseline configurations to support rollback include hardware, software, firmware, configuration files, configuration records, and ass

NIST SP 800-53 Rev 5 control CM-9.1 (Assignment of Responsibility) is defined as follows: CM-9.1 · Assignment of Responsibility Control Statement: Assign responsibility for developing the configuration management process to organizational personnel that are not directly involved in system development. Supplemental Guidance: Assign responsibility for developing the configuration management process to organizational personnel that are not directly involved in system development. In the absence of dedicated configuration management teams assigned within organizations, system developers may be tasked with developing configuration management processes using personnel who are not direc

NIST SP 800-53 Rev 5 control CM-3.7 (Review System Changes): CM-3.7 · Review System Changes Control Statement: Review changes to the system [organization-defined parameter] or when [organization-defined parameter] to determine whether unauthorized changes have occurred. Supplemental Guidance: Review changes to the system [organization-defined parameter] or when [organization-defined parameter] to determine whether unauthorized changes have occurred. Indic

Under the FedRAMP High baseline, CM-4.2 (CM-4.2 Verification of Controls): FedRAMP High Baseline · CM-4.2 · Verification of Controls Control Statement: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired outcome with regard to meeting the security and privacy requirements for the system. Supplemental Guidance: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired outcome with regard to meeting the security and p

Under the FedRAMP High baseline, CM-6.1 (CM-6.1 Automated Management, Application, and Verification): FedRAMP High Baseline · CM-6.1 · Automated Management, Application, and Verification Control Statement: Manage, apply, and verify configuration settings for [organization-defined parameter] using [organization-defined parameter]. Supplemental Guidance: Manage, apply, and verify configuration settings for [organization-defined parameter] using [organization-defined parameter]. Automated tools (e.g., hardening tools, baseline configuration tools) can improve the accuracy, consistency, and availa

NIST SP 800-53 Rev 5 control CM-8.4 (Accountability Information) is assessed by examining, interviewing, and testing: CM-8.4 · Accountability Information Control Statement: Include in the system component inventory information, a means for identifying by [organization-defined parameter] , individuals responsible and accountable for administering those components. Supplemental Guidance: Include in the system component inventory information, a means for identifying by [organization-defined parameter] , individuals responsible and accountable for administering those components. Identifying individuals who are re

NIST SP 800-171 Rev 3 control 03.04.08 (03.04.08 Authorized Software · Allow by Exception) requires organizations to implement the following: Control Statement: SR-03.04.08.a Identify software programs authorized to execute on the system. SR-03.04.08.b Implement a deny-all, allow-by-exception policy for the execution of authorized software programs on the system. SR-03.04.08.c Review and update the list of authorized software programs [organization-defined parameter]. For

practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.08.

NIST SP 800-53 Rev 5 control CM-2 (Baseline Configuration) summarizes the requirements for this control: CM-2 · Baseline Configuration Control Statement: a. Develop, document, and maintain under configuration control, a current baseline configuration of the system; and b. Review and update the baseline configuration of the system: 1. [organization-defined parameter]; 2. When required due to [organization-defined parameter] ; and 3. When system components are installed or upgraded. Supplemental Guidance: a. Develop, document, and maintain under configuration control, a current baseline confi

NIST SP 800-53 Rev 5 control CM-5 (Access Restrictions for Change) summarizes the requirements for this control: CM-5 · Access Restrictions for Change Control Statement: Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system. Supplemental Guidance: Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system. Changes to the hardware, software, or firmware components of systems or the operational procedures related to the system can potentially have significant effects on the security of

NIST SP 800-53 Rev 5 control CM-8.6 (Assessed Configurations and Approved Deviations) summarizes the requirements for this control: CM-8.6 · Assessed Configurations and Approved Deviations Control Statement: Include assessed component configurations and any approved deviations to current deployed configurations in the system component inventory. Supplemental Guidance: Include assessed component configurations and any approved deviations to current deployed configurations in the system component inventory. Assessed configurations and approved deviations focus on configuration settings established by organizations for system

NIST SP 800-53 Rev 5 control CM-8.6 (Assessed Configurations and Approved Deviations) is assessed by examining, interviewing, and testing: CM-8.6 · Assessed Configurations and Approved Deviations Control Statement: Include assessed component configurations and any approved deviations to current deployed configurations in the system component inventory. Supplemental Guidance: Include assessed component configurations and any approved deviations to current deployed configurations in the system component inventory. Assessed configurations and approved deviations focus on configuration settings established by organizations for system

NIST SP 800-171 Rev 3 control 03.04.03 (03.04.03 Configuration Change Control) requires organizations to implement the following: Control Statement: SR-03.04.03.a Define the types of changes to the system that are configuration-controlled. SR-03.04.03.b Review proposed configuration-controlled changes to the system, and approve or disapprove such changes with explicit consideration for security impacts. SR-03.04.03.c Implement and document approved configuration-controlled changes to the system. SR-03.04.03.d Monitor and review activities associated with configuration-controlled changes to the system. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.03.

Under the FedRAMP High baseline, CM-2.3 (CM-2.3 Retention of Previous Configurations): FedRAMP High Baseline · CM-2.3 · Retention of Previous Configurations Control Statement: Retain [organization-defined parameter] of previous versions of baseline configurations of the system to support rollback. Supplemental Guidance: Retain [organization-defined parameter] of previous versions of baseline configurations of the system to support rollback. Retaining previous versions of baseline configurations to support rollback include hardware, software, firmware, configuration files, config

CM-6 · Configuration Settings Control Statement: a. Establish and document configuration settings for components employed within the system that reflect the most restrictive mode consistent with operational requirements using [organization-defined parameter]; b. Implement the configuration settings; c. Identify, document, and approve any deviations from established configuration settings for [organization-defined parameter] based on [organization-defined parameter] ; and d. Monitor and control changes to the configuration settings in accordance with organizational policies and procedures. Supplemental Guidance: a. Establish and document configuration settings for components

employed within the system that reflect the most restrictive mode consistent with operational requirements using [organization-defined parameter]; b. Implement the configuration settings; c. Identify, document, and approve any deviations from established configuration settings for [organization-defined parameter] based on [organization-defined parameter] ; and d. Monitor and control changes to the configuration settings in accordance with organizational policies and procedures. Configuration settings are the parameters that can be changed in the hardware, software, or firmware components of the system that affect the security and privacy posture or functionality of the system. Information technology products for which configuration settings can be defined include mainframe computers, servers, workstations, operating systems, mobile devices, input/output devices, protocols, and applications. Parameters that impact the security posture of systems include registry settings; account, file, or directory permission settings; and settings for functions, protocols, ports, services, and remote connections. Privacy parameters are parameters impacting the privacy posture of systems, including the parameters required to satisfy other privacy controls. Privacy parameters include settings for access controls, data processing preferences, and processing and retention permissions. Organizations establish organization-wide configuration settings and subsequently derive specific configuration settings for systems. The established settings become part of the configuration baseline for the system. Common secure configurations (also known as security configuration checklists, lockdown and hardening guides, and security reference guides) provide recognized, standardized, and established benchmarks that stipulate secure configuration settings for information technology products and platforms as well as instructions for configuring those products or platforms to meet operational requirements. Common secure configurations can be developed by a variety of organizations, including information technology product developers, manufacturers, vendors, federal agencies, consortia, academia, industry, and other organizations in the public and private sectors. Implementation of a common secure configuration may be mandated at the organization level, mission and business process level, system level, or at a higher level, including by a regulatory agency. Common secure configurations include the United States Government Configuration Baseline [USGCB](#98498928-3ca3-44b3-8b1e-f48685373087) and security technical implementation guides (STIGs), which affect the implementation of [CM-6](#cm-6) and other controls such as [AC-19](#ac-19) and [CM-7](#cm-7) . The Security Content Automation Protocol (SCAP) and the defined standards within the protocol provide an effective method to uniquely identify, track, and control configuration settings.

Under the FedRAMP Moderate baseline, CM-3.4 (CM-3.4 Security and Privacy Representatives): FedRAMP Moderate Baseline · CM-3.4 · Security and Privacy Representatives Control Statement: Require [organization-defined parameter] to be members of the [organization-defined parameter]. Supplemental Guidance: Require [organization-defined parameter] to be members of the [organization-defined parameter]. Information security and privacy representatives include system security officers, senior agency information security officers, senior agency officials for privacy, or system privacy officer

and 2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]. Discussion: Configuration management policy and procedures address the controls in the CM family that are implemented within systems and organizations. The risk management strategy is an important factor in establishing such policies and procedures. Policies and procedures contribute to security and privacy assurance. Therefore, it is important that security and privacy programs collaborate on the development of configuration management policy and procedures. Security and privacy program policies and procedures at the organization level are preferable, in general, and may obviate the need for mission- or system-specific policies and procedures. The policy can be included as part of the general security and privacy policy or be represented by multiple policies that reflect the complex nature of organizations.

NIST SP 800-171 Rev 3 control 03.04.01 (03.04.01 Baseline Configuration) is assessed by examining the following: Assessment Objectives: - a current baseline configuration of the system is developed. - a current baseline configuration of the system is maintained under configuration control. - the baseline configuration of the system is updated [organization-defined parameter]. - the baseline configuration of the system is reviewed when system components are installed or modified. - the baseline configuration of the system is updated when system components are installed or modified. - the baseline configuration of the system is reviewed [organization-defined parameter].

NIST SP 800-171 Rev 3 control 03.04.06 (03.04.06 Least Functionality) is assessed by examining the following: Assessment Objectives: - the use of the following functions is prohibited or restricted: [organization-defined parameter]. - the use of the following ports is prohibited or restricted: [organization-defined parameter]. - the use of the following protocols is prohibited or restricted: [organization-defined parameter]. - the use of the following connections is prohibited or restricted: [organization-defined parameter]. - the use of the following services is prohibited or restricted: [organization-defined parameter]. - the system is reviewed [organization-defined parameter] to identify unnecessary

Under the FedRAMP High baseline, CM-7 (CM-7 Least Functionality): FedRAMP High Baseline · CM-7 · Least Functionality Control Statement: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [organization-defined parameter]. Supplemental Guidance: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [or

Related Controls: CM-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.01.b [Assignment: organization-defined frequency] at least every 12 months and after any significant incidents or significant changes occur Configuration Management 3.4.2 Configuration Settings a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings] (03.04.02.a). b. Identify, document, and approve any deviations from established configuration settings. Related Controls: CM-06 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.02.a [Assignment: organization-defined configuration settings] Apply the appropriate use of common security configurations available from the National Institute of Standards and Technology's National Checklist Program (NCP) website (<https://ncp.nist.gov/repository>) and prevent remote devices from simultaneously establishing non-remote connections with organizational systems and communicating via some other unauthorized connection to resources in external networks. Document any deviations from the published standard or source document.

Implementing 03.04.06 (03.04.06 Least Functionality) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.04.06 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.06 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control CM-7.8 (Binary or Machine Executable Code) is assessed by examining, interviewing, and testing: CM-7.8 · Binary or Machine Executable Code Control Statement: (a) Prohibit the use of binary or machine-executable code from sources with limited or no warranty or without the provision of source code; and (b) Allow exceptions only for compelling mission or operational requirements and with the approval of the authorizing official. Supplemental Guidance: (a) Prohibit the use of binary or machine-executable code from sources with limited or no warranty or without the provision of source code; a

NIST SP 800-171 Rev 3 control 03.04.08 (03.04.08 Authorized Software · Allow by Exception) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Configuration Management (CM) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control CM-7.1 (Periodic Review) summarizes the requirements for this control: CM-7.1 · Periodic Review Control Statement: (a) Review the system [organization-defined parameter]

to identify unnecessary and/or nonsecure functions, ports, protocols, software, and services; and (b) Disable or remove [organization-defined parameter]. Supplemental Guidance: (a) Review the system [organization-defined parameter] to identify unnecessary and/or nonsecure functions, ports, protocols, software, and services; and (b) Disable or remove [organization-defined parameter].

Organizations

Under the FedRAMP High baseline, CM-11 (CM-11 User-installed Software): FedRAMP High Baseline · CM-11 · User-installed Software Control Statement: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation policies through the following methods: [organization-defined parameter] ; and c. Monitor policy compliance [organization-defined parameter]. Supplemental Guidance: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation po

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Document any deviations from the published standard or source document. Configuration Management 3.4.6 System Configuration a. Configure the system to provide only mission-essential capabilities. b. Prohibit or restrict use of the following functions, ports, protocols, connections, and services: [Assignment: organization-defined functions, ports, protocols, connections, and services] (03.04.06.b). c. Review the system [Assignment: organization-defined frequency] (03.04.06.c) to identify unnecessary or nonsecure functions, ports, protocols, connections, and services. d. Disable or remove functions, ports, protocols, connections, and services that are unnecessary or nonsecure. Related Controls: CM-07, CM-07(01) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.0

NIST SP 800-53 Rev 5 control CM-3 (Configuration Change Control) summarizes the requirements for this control: CM-3 · Configuration Change Control Control Statement: a. Determine and document the types of changes to the system that are configuration-controlled; b. Review proposed configuration-controlled changes to the system and approve or disapprove such changes with explicit consideration for security and privacy impact analyses; c. Document configuration change decisions associated with the system; d. Implement approved configuration-controlled changes to the system; e. Retain records of configurati

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: CM-08, CM-08(01) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.10.b [Assignment: organization-defined frequency] at least quarterly Configuration Management 3.4.12 System Configurations for High-Risk Locations a. Issue systems or system components with the following configurations to individuals traveling to high-risk locations: [Assignment: organization-defined system configurations] (03.04.12.a). b. Apply the following security requirements to the systems or components when the individuals return from travel: [Assignment: organization-defined security requirements] (03.04.12.b). Related Controls: CM-02(07) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.12.a [Assignment: organization-defined system configurations] a config

NIST SP 800-53 Rev 5 control CM-8 (System Component Inventory) is assessed by examining, interviewing, and testing: CM-8 · System Component Inventory Control Statement: a. Develop and document an inventory of system components that: 1. Accurately reflects the system; 2. Includes all components within the system; 3. Does not include duplicate accounting of components or components assigned to any other system; 4. Is at the level of granularity deemed necessary for tracking and reporting; and 5. Includes the following information to achieve system component accountability: [organization-defined param

NIST SP 800-53 Rev 5 control CM-7.4 (Unauthorized Software · Deny-by-exception) is defined as follows: CM-7.4 · Unauthorized Software · Deny-by-exception Control Statement: (a) Identify [organization-defined parameter]; (b) Employ an allow-all, deny-by-exception policy to prohibit the execution of unauthorized software programs on the system; and (c) Review and update the list of unauthorized software programs [organization-defined parameter]. Supplemental Guidance: (a) Identify [organization-defined parameter]; (b) Employ an allow-all, deny-by-exception policy to prohibit the execution of unauthorized software programs on the system; and (c) Review and update the list of unauthorized softwar

NIST SP 800-53 Rev 5 control CM-3.1 (Automated Documentation, Notification, and Prohibition of Changes) summarizes the requirements for this control: CM-3.1 · Automated Documentation,

Notification, and Prohibition of Changes Control Statement: Use [organization-defined parameter] to: (a) Document proposed changes to the system; (b) Notify [organization-defined parameter] of proposed changes to the system and request change approval; (c) Highlight proposed changes to the system that have not been approved or disapproved within [organization-defined parameter]; (d) Prohibit changes to the system until designated approvals are received; (e) Doc

Control CM-13: DATA ACTION MAPPING Control: Develop and document a map of system data actions.

Discussion: Data actions are system operations that process personally identifiable information. The processing of such information encompasses the full information life cycle, which includes collection, generation, transformation, use, disclosure, retention, and disposal. A map of system

CHAPTER THREE PAGE 113 This publication is available free of charge f

rom: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP

800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

data actions includes discrete data actions, elements of personally identifiable information being processed in the data actions, system components involved in the data actions, and the owners or operators of the system components. Understanding what personally identifiable information is being processed (e.g., the sensitivity of the personally identifiable information), how personally identifiable information is being processed (e.g., if the data action is visible to the individual or is processed in another part of the system), and by whom (e.g., individuals may have different privacy perceptions based on the entity that is processing the personally identifiable information) provides a number of contextual factors that are important to assessing the degree of privacy risk created by the system. Data maps can be illustrated in different ways, and the level of detail may vary based on the mission and business needs of the organization. The data map may be an overlay of any system design artifact that the organization is using.

Implementing 03.04.12 (03.04.12 System and Component Configuration for High-Risk Areas) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.04.12 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.12 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Control CM-7: Fundamental design and development of the system (see SA- 8, SC-2, and SC-3). Related Controls: AC-3, AC-4, CM-2, CM-5, CM-6, CM-11, RA-5, SA-4, SA-5, SA-8, SA-9, SA-15, SC- 2, SC-3, SC-7, SC-37, SI-4. Control Enhancements: This publication is (1) LEAST FUNCTIONALITY | PERIODIC REVIEW available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>.

(a) Review the system [Assignment: organization-defined frequency] to identify unnecessary and/or nonsecure functions, ports, protocols, software, and services; and (b) Disable or remove [Assignment: organization-defined functions, ports, protocols, software, and services within the system deemed to be unnecessary and/or nonsecure].

Discussion: Organizations review functions, ports, protocols, and services provided by systems or system components to determine the functions and services that are candidates for elimination. Such reviews are especially important during transition periods from older technologies to newer technologies (e.g., transition from IPv4 to IPv6). These technology transitions may require implementing the older and newer technologies simultaneously during the transition period and returning to minimum essential functions, ports, protocols, and services at the earliest opportunity. Organizations can either decide the relative security of the function, port, protocol, and/or service or base the security decision on the assessment of other entities. Unsecure protocols include Bluetooth, FTP, and peer-to-peer networking. Related Controls: AC-18. (2) LEAST FUNCTIONALITY | PREVENT PROGRAM EXECUTION Prevent program execution in accordance with [Selection (one or more): [Assignment: organization-defined policies, rules of behavior, and/or access agreements regarding software program usage and restrictions]; rules authorizing the terms and conditions of software program usage].

Under the FedRAMP Moderate baseline, CM-5 (CM-5 Access Restrictions for Change): FedRAMP Moderate Baseline · CM-5 · Access Restrictions for Change Control Statement: Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system. Supplemental Guidance: Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system. Changes to the hardware, software, or firmware components of systems or the operational procedures related to the system can potentially have significant

NIST SP 800-53 Rev 5 control CM-2.7 (Configure Systems and Components for High-risk Areas) summarizes the requirements for this control: CM-2.7 · Configure Systems and Components for High-risk Areas Control Statement: (a) Issue [organization-defined parameter] with [organization-defined parameter] to individuals traveling to locations that the organization deems to be of significant risk; and (b) Apply the following controls to the systems or components when the individuals return from travel: [organization-defined parameter]. Supplemental Guidance: (a) Issue [organization-defined parameter] with [organization-defined parameter]

Under the FedRAMP High baseline, CM-8 (CM-8 System Component Inventory): FedRAMP High Baseline · CM-8 · System Component Inventory Control Statement: a. Develop and document an inventory of system components that: 1. Accurately reflects the system; 2. Includes all components within the system; 3. Does not include duplicate accounting of components or components assigned to any other system; 4. Is at the level of granularity deemed necessary for tracking and reporting; and 5. Includes the following information to achieve system component accountability: [or

Under the FedRAMP Moderate baseline, CM-6 (CM-6 Configuration Settings): FedRAMP Moderate Baseline · CM-6 · Configuration Settings Control Statement: a. Establish and document configuration settings for components employed within the system that reflect the most restrictive mode consistent with operational requirements using [organization-defined parameter]; b. Implement the configuration settings; c. Identify, document, and approve any deviations from established configuration settings for [organization-defined parameter] based on [organization-defined parameter] ;

NIST SP 800-171 Rev 3 control 03.04.04 (03.04.04 Impact Analyses) is assessed by examining the following: Assessment Objectives: - the security requirements for the system continue to be satisfied after the system changes have been implemented. - changes to the system are analyzed to determine potential security impacts prior to change implementation.

NIST SP 800-53 Rev 5 control CM-3.5 (Automated Security Response) is assessed by examining, interviewing, and testing: CM-3.5 · Automated Security Response Control Statement: Implement the following security responses automatically if baseline configurations are changed in an unauthorized manner: [organization-defined parameter]. Supplemental Guidance: Implement the following security responses automatically if baseline configurations are changed in an unauthorized manner: [organization-defined parameter]. Automated security responses include halting selected system functions, halting system processing, and is

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: 03.04.06.c [Assignment: organization-defined frequency] at least every 12 months, when any system functions, ports, protocols, or services changes are made, and after any significant1 incidents or significant1 changes to risks Configuration Management 3.4.8 Software Execution Authorization a. Identify software programs authorized to execute on the system. b. Implement a deny-all, allow-by-exception policy for the execution of authorized software programs on the system. c. Review and update the list of authorized software programs [Assignment: organization-defined frequency] (03.04.08.c). Related Controls: CM-07(05) ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.08.c [Assignment: organization-defined frequency] at least quarterly Configuration Management 3

NIST SP 800-53 Rev 5 control CM-8.9 (Assignment of Components to Systems) summarizes the requirements for this control: CM-8.9 · Assignment of Components to Systems Control Statement: (a) Assign system components to a system; and (b) Receive an acknowledgement from [organization-defined parameter] of this assignment. Supplemental Guidance: (a) Assign system components to a system; and (b) Receive an acknowledgement from [organization-defined parameter] of this assignment. System components that are not assigned to a system may be unmanaged, lack the required protection, and

become an organizational vulnerability

NIST SP 800-171 Rev 3 control 03.04.08 (03.04.08 Authorized Software · Allow by Exception) is assessed by examining the following: Assessment Objectives: - software programs authorized to execute on the system are identified. - a deny-all, allow-by-exception policy for the execution of authorized software programs on the system is implemented. - the list of authorized software programs is reviewed and updated [organization-defined parameter].

CM-7.3 · Registration Compliance Control Statement: Ensure compliance with [organization-defined parameter]. Supplemental Guidance: Ensure compliance with [organization-defined parameter]. Organizations use the registration process to manage, track, and provide oversight for systems and implemented functions, ports, protocols, and services.

NIST SP 800-171 Rev 3 control 03.04.06 (03.04.06 Least Functionality) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Configuration Management (CM) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

and (b) Apply the following controls to the systems or components when the individuals return from travel: [Assignment: organization-defined controls]. Discussion: When it is known that systems or system components will be in high-risk areas external to the organization, additional controls may be implemented to counter the increased threat in such areas. For example, organizations can take actions for notebook computers used by individuals departing on and returning from travel. Actions include determining the locations that are of concern, defining the required configurations for the components, ensuring that components are configured as intended before travel is initiated, and applying controls to the components after travel is completed. Specially configured notebook computers include computers with sanitized hard drives, limited applications, and more stringent configuration settings.

NIST SP 800-53 Rev 5 control CM-7.9 (Prohibiting The Use of Unauthorized Hardware) summarizes the requirements for this control: CM-7.9 · Prohibiting The Use of Unauthorized Hardware Control Statement: (a) Identify [organization-defined parameter]; (b) Prohibit the use or connection of unauthorized hardware components; (c) Review and update the list of authorized hardware components [organization-defined parameter]. Supplemental Guidance: (a) Identify [organization-defined parameter]; (b) Prohibit the use or connection of unauthorized hardware components; (c) Review and update the list of authorized hardware components

NIST SP 800-53 Rev 5 control CM-4.1 (Separate Test Environments) summarizes the requirements for this control: CM-4.1 · Separate Test Environments Control Statement: Analyze changes to the system in a separate test environment before implementation in an operational environment, looking for security and privacy impacts due to flaws, weaknesses, incompatibility, or intentional malice. Supplemental Guidance: Analyze changes to the system in a separate test environment before implementation in an operational environment, looking for security and privacy impacts due to flaws, weaknesses, incompatibility, o

NIST SP 800-171 Rev 3 control 03.04.11 (03.04.11 Information Location) is assessed by examining the following: Assessment Objectives: - the location of CUI is identified and documented. - the system components on which CUI is processed are identified and documented. - the system components on which CUI is stored are identified and documented. - changes to the system or system component location where CUI is processed are documented. - changes to the system or system component location where CUI is stored are documented.

NIST SP 800-171 Rev 3 control 03.04.04 (03.04.04 Impact Analyses) is assessed by examining the following: Assessment Objectives: - the security requirements for the system continue to be satisfied after the system changes have been implemented. - changes to the system are analyzed to determine potential security impacts prior to change implementation.

Control CM-1: a purchaser for the specific website. A FIDO Certified Authenticator will always have this logic implemented because it is part of the protocol conformance testing to achieve the FIDO

NIST SP 800-171 Rev 3 control 03.04.02 (03.04.02 Configuration Settings) is assessed by examining the following: Assessment Objectives: - the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented: [organization-defined parameter]. - any deviations from established configuration settings are identified and documented. - any deviations from established configuration settings are approved. - the following configuration settings for the system are implemented: [organization-defined parameter].

NIST SP 800-171 Rev 3 control 03.04.05 (03.04.05 Access Restrictions for Change) requires organizations to implement the following: 03.04.05 · Access Restrictions for Change Supplemental Guidance: Changes to the hardware, software, or firmware components of the system or the operational procedures related to the system can have potentially significant effects on the security of the system. Therefore, organizations permit only qualified and authorized individuals to access the system for the purpose of initiating changes. Access restrictions include physical and logical access controls, software libraries, workflow automatio For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.05.

Control PM-5: SYSTEM INVENTORY Control: Develop and update [Assignment: organization-defined frequency] an inventory of organizational systems. Discussion: [OMB A-130] provides guidance on developing systems inventories and associated reporting requirements. System inventory refers to an organization-wide inventory of systems, not system components as described in CM-8. Related Controls: None. Control Enhancements: (1) SYSTEM INVENTORY | INVENTORY OF PERSONALLY IDENTIFIABLE INFORMATION Establish, maintain, and update [Assignment: organization-defined frequency] an inventory of all systems, applications, and projects that process personally identifiable information. Discussion: An inventory of systems, applications, and projects that process personally identifiable information supports the mapping of data actions, providing individuals with privacy notices, maintaining accurate personally identifiable information, and limiting the processing of personally identifiable information when such information is not needed for operational purposes. Organizations may use this inventory to ensure that systems only process the personally identifiable information for authorized purposes and that this processing is still relevant and necessary for the purpose specified therein. Related Controls: AC-3, CM-8, CM-12, CM-13, PL-8, PM-22, PT-3, PT-5, SI-12, SI-18. References: [OMB A-130], [IR 8062].

FedRAMP Moderate Baseline · CM-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] configuration management policy that: 2. Procedures to facilitate the implementation of the configuration management policy and the associated configuration management controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the configuration management policy and procedures; and c. Review and update the current configuration management: 1. Policy [organization-defined parameter] and following [organization-defined parameter] ; and 2. Procedures [organization-defined parameter] and following [organization-defined parameter]. Supplemental Guidance: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] configuration management policy that: 2. Procedures to facilitate the implementation of the configuration management policy and the associated configuration management controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the configuration management policy and procedures; and c. Review and update the current configuration management: 1. Policy [organization-defined parameter] and following [organization-defined parameter] ; and 2. Procedures [organization-defined parameter] and following [organization-defined parameter]. Configuration management policy and procedures address the controls in the CM family that are implemented within systems and organizations. The risk management strategy is an important factor in establishing such policies and procedures. Policies and procedures contribute to security and privacy assurance. Therefore, it is important that security and privacy programs collaborate on the development of configuration management policy and procedures. Security and privacy program policies and procedures at the organization level are preferable, in general, and may obviate the need for mission- or system-specific policies and procedures. The policy can be included as part of the general security and privacy policy or be represented by multiple policies that reflect the complex nature of organizations. Procedures can be established for security and privacy programs, for

mission/business processes, and for systems, if needed. Procedures describe how the policies or controls are implemented and can be directed at the individual or role that is the object of the procedure. Procedures can be documented in system security and privacy plans or in one or more separate documents. Events that may precipitate an update to configuration management policy and procedures include, but are not limited to, assessment or audit findings, security incidents or breaches, or changes in applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Simply restating controls does not constitute an organizational policy or procedure. Assessment Objectives: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] configuration management policy that: 2. Procedures to facilitate the implementation of the configuration management policy and the associated configuration management controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the configuration management policy and procedures; and c. Review and update the current configuration management: 1. Policy [organization-defined parameter] and following [organization-defined parameter] ; and 2. Procedures [organization-defined parameter] and following [organization-defined parameter]. FedRAMP Parameter Values: cm-1_prm_1: organization-defined personnel or roles cm-01_odp.01: personnel or roles to whom the configuration management policy is to be disseminated is/are defined; cm-01_odp.02: personnel or roles to whom the configuration management procedures are to be disseminated is/are defined; cm-01_odp.04: an official to manage the configuration management policy and procedures is defined; cm-01_odp.05: at least every 3 years cm-01_odp.06: events that would require the current configuration management policy to be reviewed and updated are defined; cm-01_odp.07: at least annually cm-01_odp.08: significant changes

NIST SP 800-53 Rev 5 control CM-7 (Least Functionality) is assessed by examining, interviewing, and testing: CM-7 · Least Functionality Control Statement: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [organization-defined parameter]. Supplemental Guidance: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [organization-defined param

NIST SP 800-171 Rev 3 control 03.04.02 (03.04.02 Configuration Settings) requires organizations to implement the following: Control Statement: SR-03.04.02.a Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [organization-defined parameter] . SR-03.04.02.b Identify, document, and approve any deviations from established configuration settings. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.02.

NIST SP 800-53 Rev 5 control CM-8.8 (Automated Location Tracking) is assessed by examining, interviewing, and testing: CM-8.8 · Automated Location Tracking Control Statement: Support the tracking of system components by geographic location using [organization-defined parameter]. Supplemental Guidance: Support the tracking of system components by geographic location using [organization-defined parameter]. The use of automated mechanisms to track the location of system components can increase the accuracy of component inventories. Such capability may help organizations rapidly identify the location and responsib

NIST SP 800-53 Rev 5 control CM-7.2 (Prevent Program Execution) is assessed by examining, interviewing, and testing: CM-7.2 · Prevent Program Execution Control Statement: Prevent program execution in accordance with [organization-defined parameter]. Supplemental Guidance: Prevent program execution in accordance with [organization-defined parameter]. Prevention of program execution addresses organizational policies, rules of behavior, and/or access agreements that restrict software usage and the terms and conditions imposed by the developer or manufacturer, including software licensing and copyrights. Restrict

NIST SP 800-53 Rev 5 control CM-12.1 (Automated Tools to Support Information Location) summarizes the requirements for this control: CM-12.1 · Automated Tools to Support Information Location Control Statement: Use automated tools to identify [organization-defined parameter] on [organization-defined parameter] to ensure controls are in place to protect organizational information and individual privacy. Supplemental Guidance: Use automated tools to identify

[organization-defined parameter] on [organization-defined parameter] to ensure controls are in place to protect organizational information and individual privacy. The use

NIST SP 800-53 Rev 5 control CM-10.1 (Open-source Software) summarizes the requirements for this control: CM-10.1 · Open-source Software Control Statement: Establish the following restrictions on the use of open-source software: [organization-defined parameter]. Supplemental Guidance: Establish the following restrictions on the use of open-source software: [organization-defined parameter]. Open-source software refers to software that is available in source code form. Certain software rights normally reserved for copyright holders are routinely provided under software license agreements that permit

NIST SP 800-53 Rev 5 control CM-2.2 (Automation Support for Accuracy and Currency) summarizes the requirements for this control: CM-2.2 · Automation Support for Accuracy and Currency Control Statement: Maintain the currency, completeness, accuracy, and availability of the baseline configuration of the system using [organization-defined parameter]. Supplemental Guidance: Maintain the currency, completeness, accuracy, and availability of the baseline configuration of the system using [organization-defined parameter]. Automated mechanisms that help organizations maintain consistent baseline configurations for systems inclu

NIST SP 800-171 Rev 3 control 03.04.03 (03.04.03 Configuration Change Control) is assessed by examining the following: Assessment Objectives: - the types of changes to the system that are configuration-controlled are defined. - proposed configuration-controlled changes to the system are reviewed with explicit consideration for security impacts. - proposed configuration-controlled changes to the system are approved or disapproved with explicit consideration for security impacts. - activities associated with configuration-controlled changes to the system are monitored. - activities associated with configuration-controlled changes to the system are reviewed. - approved configuration-controlled changes to the syst

NIST SP 800-171 Rev 3 control 03.04.05 (03.04.05 Access Restrictions for Change) is assessed by examining the following: Assessment Objectives: - physical access restrictions associated with changes to the system are defined and documented. - physical access restrictions associated with changes to the system are approved. - physical access restrictions associated with changes to the system are enforced. - logical access restrictions associated with changes to the system are defined and documented. - logical access restrictions associated with changes to the system are approved. - logical access restrictions associated with changes to the system are enforced.

Under the FedRAMP Moderate baseline, CM-3 (CM-3 Configuration Change Control): FedRAMP Moderate Baseline · CM-3 · Configuration Change Control Control Statement: a. Determine and document the types of changes to the system that are configuration-controlled; b. Review proposed configuration-controlled changes to the system and approve or disapprove such changes with explicit consideration for security and privacy impact analyses; c. Document configuration change decisions associated with the system; d. Implement approved configuration-controlled changes to the system; e. R

NIST SP 800-53 Rev 5 control CM-7.5 (Authorized Software · Allow-by-exception) summarizes the requirements for this control: CM-7.5 · Authorized Software · Allow-by-exception Control Statement: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs on the system; and (c) Review and update the list of authorized software programs [organization-defined parameter]. Supplemental Guidance: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the execution of authorized soft

NIST SP 800-53 Rev 5 control CM-7.7 (Code Execution in Protected Environments) summarizes the requirements for this control: CM-7.7 · Code Execution in Protected Environments Control Statement: Allow execution of binary or machine-executable code only in confined physical or virtual machine environments and with the explicit approval of [organization-defined parameter] when such code is: (a) Obtained from sources with limited or no warranty; and/or (b) Without the provision of source code. Supplemental Guidance: Allow execution of binary or machine-executable code only in confined physical or virtual machine environ

NIST SP 800-171 Rev 3 control 03.04.11 (03.04.11 Information Location) falls under the Configuration

Management family. Control Statement: SR-03.04.11.a Identify and document the location of CUI and the system components on which the information is processed and stored. SR-03.04.11.b Document changes to the system or system component location where CUI is processed and stored. Supplemental Guidance: Information location addresses the need to understand the specific system components where CUI is being processed and stored and the users who have access to CUI so that appropriate protection mechanisms can be provided, including information flow controls, access controls, and information management.

NIST SP 800-53 Rev 5 control CM-7.5 (Authorized Software · Allow-by-exception) is defined as follows: CM-7.5 · Authorized Software · Allow-by-exception Control Statement: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs on the system; and (c) Review and update the list of authorized software programs [organization-defined parameter]. Supplemental Guidance: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs on the system; and (c) Review and update the list of authorized software programs [org

NIST SP 800-53 Rev 5 control CM-8.1 (Updates During Installation and Removal) is assessed by examining, interviewing, and testing: CM-8.1 · Updates During Installation and Removal Control Statement: Update the inventory of system components as part of component installations, removals, and system updates. Supplemental Guidance: Update the inventory of system components as part of component installations, removals, and system updates. Organizations can improve the accuracy, completeness, and consistency of system component inventories if the inventories are updated as part of component installations or removals or during g

Implementing 03.04.03 (03.04.03 Configuration Change Control) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.04.03 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.03 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA, DLO ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Expose (Detect) REFERENCES Source Control: CM-02(02) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.04.05E Dual Authorization for System Changes 993

From the NIST SP 800-172 Rev 3 Final Public Draft: Such repositories can help NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 organizations rapidly identify the location and responsible individuals of system 1055 components that have been compromised, breached, or are otherwise in need of mitigation actions. This requirement enhances SP 800-171 requirement 03.04.10. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: CM-08(07) 3.5. Identification and Authentication 03.05.01E Cryptographic Bidirectional Authentication Authenticate [Assignment: organization-defined devices and/or types of devices] before establishing a system connection using bidirectional authentication that is cryptographically based. DISCUSSION

Implementing 03.04.01 (03.04.01 Baseline Configuration) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.04.01 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles

application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.01 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control CM-3.6 (Cryptography Management) is assessed by examining, interviewing, and testing: CM-3.6 · Cryptography Management Control Statement: Ensure that cryptographic mechanisms used to provide the following controls are under configuration management: [organization-defined parameter]. Supplemental Guidance: Ensure that cryptographic mechanisms used to provide the following controls are under configuration management: [organization-defined parameter]. The controls referenced in the control enhancement refer to security and privacy controls from the control catalog. Regardless of t

NIST SP 800-171 Rev 3 control 03.04.02 (03.04.02 Configuration Settings) is assessed by examining the following: Assessment Objectives: - the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements are established and documented: [organization-defined parameter]. - any deviations from established configuration settings are identified and documented. - any deviations from established configuration settings are approved. - the following configuration settings for the system are implemented: [organization-defined parameter].

NIST SP 800-53 Rev 5 control CM-11 (User-installed Software) summarizes the requirements for this control: CM-11 · User-installed Software Control Statement: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation policies through the following methods: [organization-defined parameter] ; and c. Monitor policy compliance [organization-defined parameter]. Supplemental Guidance: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation policies through the follo

Under the FedRAMP High baseline, CM-7.5 (CM-7.5 Authorized Software · Allow-by-exception): FedRAMP High Baseline · CM-7.5 · Authorized Software · Allow-by-exception Control Statement: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs on the system; and (c) Review and update the list of authorized software programs [organization-defined parameter]. Supplemental Guidance: (a) Identify [organization-defined parameter]; (b) Employ a deny-all, permit-by-exception policy to allow the exec

NIST SP 800-171 Rev 3 control 03.04.01 (03.04.01 Baseline Configuration) falls under the Configuration Management family. Control Statement: SR-03.04.01.a Develop and maintain under configuration control, a current baseline configuration of the system. SR-03.04.01.b Review and update the baseline configuration of the system [organization-defined parameter] and when system components are installed or modified. Supplemental Guidance: Baseline configurations for the system and system components include aspects of connectivity, operation, and communications. Baseline configurations are documented, formally reviewed, and agreed-upon specifications for the system or configuration items within the system. Baseline configurations serve as a basis for future builds, releases, or changes to the system and include information about system components, operational procedures, network topology, and the placement o

Control CM-8(5): he narratives are supplemented by the other material in this section, including defect check tables (defining the tests to be used), and are summarized in the Control Allocation Tables in Section 3.4. The roles referenced in the narratives match the roles defined by NIST in relevant special publications (e.g., NIST SP 800-37) and/or the VUL-specific roles defined in Section 2.7. The roles can be adapted and/or customized to the organization as described in the introduction to Section 3. The determination statements listed here have been derived from the relevant control item language, specifically modified by the following three adjustments: 1. The limiting or scoping phrase {software} (possibly along with additional information within the brackets as appropriate) is inserted in determination statements where necessary for control items that apply to more capability areas than just VUL. The limiting phrase tailors the control item to remain within VUL since the same control item could appear in other capabilities with the relevant

scoping for that capability. For example, using the limiting phrase {·software·} is appropriate where the control could apply to vulnerabilities in both software and hardware. 2. Where a control item includes inherently different actions that are best assessed by different defect checks (typically because the assessment criteria are different), the control item may be divided into multiple VUL-applicable determination statements. 3. Part of a control item may not apply to VUL while another part does. For example, consider the control item RA-5(b): the control text lists actions that do not necessarily apply to VUL capability, such as ensuring that scanning tools use standards for enumerating platforms (applies to the HWAM and SWAM capabilities) and assessing improper configurations not related to vulnerabilities (applies to the CSM capability).

NIST SP 800-53 Rev 5 control CM-5.5 (Privilege Limitation for Production and Operation) is assessed by examining, interviewing, and testing: CM-5.5 · Privilege Limitation for Production and Operation Control Statement: (a) Limit privileges to change system components and system-related information within a production or operational environment; and (b) Review and reevaluate privileges [organization-defined parameter]. Supplemental Guidance: (a) Limit privileges to change system components and system-related information within a production or operational environment; and (b) Review and reevaluate privileges [organization-defined par

Under the FedRAMP High baseline, CM-7.1 (CM-7.1 Periodic Review): FedRAMP High Baseline · CM-7.1 · Periodic Review Control Statement: (a) Review the system [organization-defined parameter] to identify unnecessary and/or nonsecure functions, ports, protocols, software, and services; and (b) Disable or remove [organization-defined parameter]. Supplemental Guidance: (a) Review the system [organization-defined parameter] to identify unnecessary and/or nonsecure functions, ports, protocols, software, and services; and (b) Disable or remove [organization-defined p

Control CM-8: si publication is a vaillabefree of charge from : h t
t p s : / / d o i . o r g / 1 0 . 6 0 2 8 / N S T S P . 8 0 0 - 5 3 r 5 . I NIST SP 800-53, REV. 5
SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Discussion: Organizations may implement centralized system component inventories that include components from all organizational systems. Centralized repositories of component inventories provide opportunities for efficiencies in accounting for organizational hardware, software, and firmware assets. Such repositories may also help organizations rapidly identify the location and responsible individuals of components that have been compromised, breached, or are otherwise in need of mitigation actions. Organizations ensure that the resulting centralized inventories include system-specific information required for proper component accountability. Related Controls: None. (8) SYSTEM COMPONENT INVENTORY | AUTOMATED LOCATION TRACKING Support the tracking of system components by geographic location using [Assignment: organization-defined automated mechanisms]. Discussion: The use of automated mechanisms to track the location of system components can increase the accuracy of component inventories. Such capability may help organizations rapidly identify the location and responsible individuals of system components that have been compromised, breached, or are otherwise in need of mitigation actions. The use of tracking mechanisms can be coordinated with senior agency officials for privacy if there are implications that affect individual privacy. Related Controls: None.

NIST SP 800-53 Rev 5 control CM-10 (Software Usage Restrictions) summarizes the requirements for this control: CM-10 · Software Usage Restrictions Control Statement: a. Use software and associated documentation in accordance with contract agreements and copyright laws; b. Track the use of software and associated documentation protected by quantity licenses to control copying and distribution; and c. Control and document the use of peer-to-peer file sharing technology to ensure that this capability is not used for the unauthorized distribution, display, performance, or reproduction of copyrighted work.

NIST SP 800-171 Rev 3 control 03.04.05 (03.04.05 Access Restrictions for Change) falls under the Configuration Management family. 03.04.05 · Access Restrictions for Change Supplemental Guidance: Changes to the hardware, software, or firmware components of the system or the operational procedures related to the system can have potentially significant effects on the security of the system. Therefore, organizations permit only qualified and authorized individuals to access the system for the purpose of initiating changes. Access restrictions include physical and logical access controls, software libraries, workflow automatio Supplemental Guidance: Changes to the

hardware, software, or firmware components of the system or the operational procedures related to the system can have potentially significant effects on the security of the system. Therefore, organizations permit only qualified and authorized individuals to access the system for the purpose of initiating changes. Access restrictions include physical and logical access controls, software libraries, workflow automation, media libraries, abstract layers (i.e.,

and b. Take the following actions when unauthorized changes to the software, firmware, and information are detected: [Assignment: organization-defined actions]. Discussion: Unauthorized changes to software, firmware, and information can occur due to errors or malicious activity. Software includes operating systems (with key internal components, such as kernels or drivers), middleware, and applications. Firmware interfaces include Unified Extensible Firmware Interface (UEFI) and Basic Input/Output System (BIOS). Information includes personally identifiable information and metadata that contains security and privacy attributes associated with information. Integrity-checking mechanisms including parity checks, cyclical redundancy checks, cryptographic hashes, and associated tools can automatically monitor the integrity of systems and hosted applications. Related Controls: AC-4, CM-3, CM-7, CM-8, MA-3, MA-4, RA-5, SA-8, SA-9, SA-10, SC-8, SC-12,

NIST SP 800-171 Rev 3 control 03.04.12 (03.04.12 System and Component Configuration for High-Risk Areas) requires organizations to implement the following: Control Statement: SR-03.04.12.a Issue systems or system components with the following configurations to individuals traveling to high-risk locations: [organization-defined parameter]. SR-03.04.12.b Apply the following security requirements to the systems or components when the individuals return from travel: [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.12.

Under the FedRAMP High baseline, CM-10 (CM-10 Software Usage Restrictions): FedRAMP High Baseline · CM-10 · Software Usage Restrictions Control Statement: a. Use software and associated documentation in accordance with contract agreements and copyright laws; b. Track the use of software and associated documentation protected by quantity licenses to control copying and distribution; and c. Control and document the use of peer-to-peer file sharing technology to ensure that this capability is not used for the unauthorized distribution, display, performance, or reproduction

NIST SP 800-53 Rev 5 control CM-8.1 (Updates During Installation and Removal) is defined as follows: CM-8.1 · Updates During Installation and Removal Control Statement: Update the inventory of system components as part of component installations, removals, and system updates. Supplemental Guidance: Update the inventory of system components as part of component installations, removals, and system updates. Organizations can improve the accuracy, completeness, and consistency of system component inventories if the inventories are updated as part of component installations or removals or during general system updates. If inventories are not updated at these key times, there is a greater likelihood

NIST SP 800-171 Rev 3 control 03.04.10 (03.04.10 System Component Inventory) is assessed by examining the following: Assessment Objectives: - an inventory of system components is developed and documented. - the system component inventory is reviewed [organization-defined parameter]. - the system component inventory is updated [organization-defined parameter]. - the system component inventory is updated as part of component installations. - the system component inventory is updated as part of component removals. - the system component inventory is updated as part of system updates.

Under the FedRAMP High baseline, CM-4.1 (CM-4.1 Separate Test Environments): FedRAMP High Baseline · CM-4.1 · Separate Test Environments Control Statement: Analyze changes to the system in a separate test environment before implementation in an operational environment, looking for security and privacy impacts due to flaws, weaknesses, incompatibility, or intentional malice. Supplemental Guidance: Analyze changes to the system in a separate test environment before implementation in an operational environment, looking for security and privacy impacts due to flaws, weaknesses

Implementing 03.04.10 (03.04.10 System Component Inventory) differs between cloud and on-premises environments in several ways: **On-premises**: The organization has direct control over all

infrastructure components. Implementation of 03.04.10 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control.

****Cloud (IaaS/PaaS/SaaS)**:** Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.10 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

M as having weaknesses are monitored more frequently until remediation of the weakness is complete. Note that not all weaknesses require the same level of monitoring. For example, weaknesses deemed in the SAR to be of minor or low -impact risk to the system or organization are monitored less frequently than a weakness with a higher-impact risk to the system or organization. - Organizational risk tolerance. 36 Organizations with a low tolerance for risk (e.g., organizations that process, store, or transmit large amounts of proprietary and/or personally identifiable information (PII), organizations with numerous high- impact systems, organizations facing specific persistent threats) monitor more frequently than organizations with a higher tolerance for risk (e.g., organizations with primarily low - and moderate-impact systems that process, store, or transmit very little PII and/or proprietary information). - Threat information . Organizations consider current credible threat information, including known exploits and attack patterns, 37 when establishing monitoring frequencies. For instance, if a specific attack is developed which exploits a vulnerability of an implemented technology, temporary or permanent increases to the monitoring frequencies for related controls or metrics may help provide protection from the threat. - Vulnerability information . 38 Organizations consider current vulnerability information with respect to information technology products when establishing monitoring frequencies. For 34 System impact levels are in accordance with FIPS 199 and NIST SP 800-60. 35 See NIST SP 800-34, as amended, Contingency Planning Guide for Federal Information Systems, May 2010. 36 See NIST SP 800-39, as amended, for more information on how to determine organizational risk tolerance. 37 Attack patterns describe common methods for exploiting software, based on in- depth analysis of specific realworld attack examples.

NIST SP 800-53 Rev 5 control CM-3.1 (Automated Documentation, Notification, and Prohibition of Changes) is assessed by examining, interviewing, and testing: CM-3.1 · Automated Documentation, Notification, and Prohibition of Changes Control Statement: Use [organization-defined parameter] to: (a) Document proposed changes to the system; (b) Notify [organization-defined parameter] of proposed changes to the system and request change approval; (c) Highlight proposed changes to the system that have not been approved or disapproved within [organization-defined parameter]; (d) Prohibit changes to the system until designated approvals are received; (e) Doc

NIST SP 800-53 Rev 5 control CM-12.1 (Automated Tools to Support Information Location) is defined as follows: CM-12.1 · Automated Tools to Support Information Location Control Statement: Use automated tools to identify [organization-defined parameter] on [organization-defined parameter] to ensure controls are in place to protect organizational information and individual privacy. Supplemental Guidance: Use automated tools to identify [organization-defined parameter] on [organization-defined parameter] to ensure controls are in place to protect organizational information and individual privacy. The use of automated tools helps to increase the effectiveness and efficiency of the information location ca

| ID.AM-1: Physical devices and systems within the organization are inventoried ISO/IEC 27001:2013 A.8.1.1, A.8.1.2 NIST SP 800-53 Rev. 5 CM-8, PM- 5 | An inventory of physical devices should be undertaken, reviewed, and maintained to ensure these devices are not vulnerable to ransomware. It is also beneficial to have a hardware inventory during the recovery phases after a ransomware attack, should a re- installation of applications be necessary. | | Asset Management (ID.AM): The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy. | ID.AM-2: Software platforms and applications within the organization are inventoried ISO/IEC 27001:2013 A.8.1.1, A.8.1.2 NIST SP 800-53 Rev. 5 CM-8, PM- 5 | Software inventories may track information such as software name and version, devices where it is currently installed, last patch date, and current known vulnerabilities. This

information supports the remediation of vulnerabilities that could be exploited in ransomware attacks. | Asset Management (ID.AM): The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy. | ID.AM-3: Organizational communication and data flows are mapped ISO/IEC 27001:2013 A.13.2.1, A.13.2.2 NIST SP 800-53 Rev. 5 AC-4, CA- 3, CA-9, PL-8 | This helps to enumerate what information or processes are at risk, should the attackers move laterally within an environment.

Under the FedRAMP High baseline, CM-2.7 (CM-2.7 Configure Systems and Components for High-risk Areas): FedRAMP High Baseline · CM-2.7 · Configure Systems and Components for High-risk Areas Control Statement: (a) Issue [organization-defined parameter] with [organization-defined parameter] to individuals traveling to locations that the organization deems to be of significant risk; and (b) Apply the following controls to the systems or components when the individuals return from travel: [organization-defined parameter]. Supplemental Guidance: (a) Issue [organization-defined parameter] with [organi

NIST SP 800-171 Rev 3 control 03.04.03 (03.04.03 Configuration Change Control) is assessed by examining the following: Assessment Objectives: - the types of changes to the system that are configuration-controlled are defined. - proposed configuration-controlled changes to the system are reviewed with explicit consideration for security impacts. - proposed configuration-controlled changes to the system are approved or disapproved with explicit consideration for security impacts. - activities associated with configuration-controlled changes to the system are monitored. - activities associated with configuration-controlled changes to the system are reviewed. - approved configuration-controlled changes to the syst

NIST SP 800-53 Rev 5 control CM-6.2 (Respond to Unauthorized Changes) is assessed by examining, interviewing, and testing: CM-6.2 · Respond to Unauthorized Changes Control Statement: Take the following actions in response to unauthorized changes to [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Take the following actions in response to unauthorized changes to [organization-defined parameter]: [organization-defined parameter]. Responses to unauthorized changes to configuration settings include alerting designated organizational personnel, restoring established configurati

NIST SP 800-171 Rev 3 control 03.04.11 (03.04.11 Information Location) requires organizations to implement the following: Control Statement: SR-03.04.11.a Identify and document the location of CUI and the system components on which the information is processed and stored. SR-03.04.11.b Document changes to the system or system component location where CUI is processed and stored. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.04.11.

NIST SP 800-53 Rev 5 control CM-11 (User-installed Software) is assessed by examining, interviewing, and testing: CM-11 · User-installed Software Control Statement: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation policies through the following methods: [organization-defined parameter] ; and c. Monitor policy compliance [organization-defined parameter]. Supplemental Guidance: a. Establish [organization-defined parameter] governing the installation of software by users; b. Enforce software installation policies through the follo

NIST SP 800-53 Rev 5 control CM-8.8 (Automated Location Tracking) summarizes the requirements for this control: CM-8.8 · Automated Location Tracking Control Statement: Support the tracking of system components by geographic location using [organization-defined parameter]. Supplemental Guidance: Support the tracking of system components by geographic location using [organization-defined parameter]. The use of automated mechanisms to track the location of system components can increase the accuracy of component inventories. Such capability may help organizations rapidly identify the location and responsib

NIST SP 800-53 Rev 5 control CM-4.2 (Verification of Controls) summarizes the requirements for this control: CM-4.2 · Verification of Controls Control Statement: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired

outcome with regard to meeting the security and privacy requirements for the system. Supplemental Guidance: After system changes, verify that the impacted controls are implemented correctly, operating as intended, and producing the desired outcome with regard to meeting the security and privacy requirements for

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: CM-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.01.b [Assignment: organization-defined frequency] at least every 12 months and after any significant incidents or significant changes occur Configuration Management 3.4.2 Configuration Settings a. Establish, document, and implement the following configuration settings for the system that reflect the most restrictive mode consistent with operational requirements: [Assignment: organization-defined configuration settings] (03.04.02.a). b. Identify, document, and approve any deviations from established configuration settings. Related Controls: CM-06 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.04.02.a [Assignment: organization-defined configuration settings] Apply

Under the FedRAMP Moderate baseline, CM-1 (CM-1 Policy and Procedures): FedRAMP Moderate Baseline · CM-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] configuration management policy that: 2. Procedures to facilitate the implementation of the configuration management policy and the associated configuration management controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the configuration

Under the FedRAMP High baseline, CM-8.4 (CM-8.4 Accountability Information): FedRAMP High Baseline · CM-8.4 · Accountability Information Control Statement: Include in the system component inventory information, a means for identifying by [organization-defined parameter], individuals responsible and accountable for administering those components. Supplemental Guidance: Include in the system component inventory information, a means for identifying by [organization-defined parameter], individuals responsible and accountable for administering those components. Identify in

Implementing 03.04.05 (03.04.05 Access Restrictions for Change) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.04.05 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.05 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Under the FedRAMP Moderate baseline, CM-10 (CM-10 Software Usage Restrictions): FedRAMP Moderate Baseline · CM-10 · Software Usage Restrictions Control Statement: a. Use software and associated documentation in accordance with contract agreements and copyright laws; b. Track the use of software and associated documentation protected by quantity licenses to control copying and distribution; and c. Control and document the use of peer-to-peer file sharing technology to ensure that this capability is not used for the unauthorized distribution, display, performance, or reprodu

NIST SP 800-53 Rev 5 control CM-6.2 (Respond to Unauthorized Changes) summarizes the requirements for this control: CM-6.2 · Respond to Unauthorized Changes Control Statement: Take the following actions in response to unauthorized changes to [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Take the following actions in response to unauthorized changes to [organization-defined parameter]: [organization-defined parameter]. Responses to unauthorized changes to configuration settings include alerting designated organizational personnel, restoring established configurati

NIST SP 800-171 Rev 3 control 03.04.05 (03.04.05 Access Restrictions for Change) is assessed by examining the following: Assessment Objectives: - physical access restrictions associated with changes to the system are defined and documented. - physical access restrictions associated with

changes to the system are approved. - physical access restrictions associated with changes to the system are enforced. - logical access restrictions associated with changes to the system are defined and documented. - logical access restrictions associated with changes to the system are approved. - logical access restrictions associated with changes to the system are enforced.

Under the FedRAMP Moderate baseline, CM-7 (CM-7 Least Functionality): FedRAMP Moderate Baseline · CM-7 · Least Functionality Control Statement: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [organization-defined parameter]. Supplemental Guidance: a. Configure the system to provide only [organization-defined parameter] ; and b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services:

NIST SP 800-171 Rev 3 control 03.04.02 (03.04.02 Configuration Settings) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Configuration Management (CM) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Control RA-5: tion system: (a) [Assignment: organization-defined frequency]. | Moderate | DS | Otherwise, the desired state might not be updated as needed to maintain appropriate security. | | CM-2(1)(b){1} | Determine if the organization: reviews and updates the baseline configuration of the information system: (b) When required due to [Assignment organization-defined circumstances]. | Moderate | DS | Otherwise, desired state might not be updated based on the organization-defined circumstances. | | CM-2(1)(c){1} | Determine if the organization: reviews and updates the baseline configuration of the information system: (c) As an integral part of information system component installations and upgrades. | Moderate | DS | Otherwise, desired state might not be updated as appropriate when component installations and updates occur. | | CM-2(2){1} | Determine if the organization: employs automated mechanisms to maintain an up-to- date, complete, accurate, and readily available baseline configuration of the information system. | High | DS | Otherwise, accurate testing information might not be provided. | | CM-3(a){1} | Determine if the organization: employs automated mechanisms to determine the types of changes to the system {installed software} that are configuration-controlled. | Moderate | DS | Otherwise, the desired state might not specify all machine-readable data needed for implemented defect checks. | | CM-3(b){1} | Determine if the organization: reviews proposed configuration-controlled changes to the {software of the} system and approves or disapproves such changes. | Moderate | DS | Otherwise, the decisions on desired state might not adequately reflect security impact of changes.

NIST SP 800-53 Rev 5 control CM-7.3 (Registration Compliance) summarizes the requirements for this control: CM-7.3 · Registration Compliance Control Statement: Ensure compliance with [organization-defined parameter]. Supplemental Guidance: Ensure compliance with [organization-defined parameter]. Organizations use the registration process to manage, track, and provide oversight for systems and implemented functions, ports, protocols, and services.

Implementing 03.04.11 (03.04.11 Information Location) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.04.11 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.04.11 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.